

Playbooks & Confirmed Incident Triage

What a Playbook Is

A **decision tree with steps and owners**, codified into repeatable runbook. The SOC goal: the *first* responder doesn't improvise the *first* time.

Anatomy:

```
name: Ransomware - Initial Response
triggers: [edr "ransomware" alert, files .locked, fake ransom note]
steps:
  - id: 1
    action: Confirm scope - isolate host from network (document IP)
    owner: Tier1
  - id: 2
    action: Preserve: memory capture + disk snapshot before reboot
    owner: DFIR
  - id: 3
    action: Notify IR lead + business owner (template in annex)
    owner: Tier1
  - id: 4
    action: Block C2 (if identified) at firewall
    owner: Security Eng
  - id: 5
    action: Begin eradication after IR lead go-signal
    owner: IR
```

Confirmed Incident Triage (< the golden hour)

When an alert becomes a case:

Freeze concerns – take the alert seriously; don't let one "maybe nothing" derail

Initial scope message – sources, assets, earliest timestamp you can see

Evidence grab NOW – before remediation kills the trail

Isolation without frying evidence – cut network, DON'T reboot/change first

Containment vs. evidence: the eternal tension – resolved by "do the safe action, capture first"

The Triage Room Technique

For real incidents: a **virtual incident room** (chat channel) with:

- The case timeline pinned to top

- Owners + decision-makers in the loop

- External comms channel for non-sec people

Decision log: every major call and its owner – recoverable rationales for law and next-day sanity.

Playbooks in SOAR

Automation runs steps, not people:

- auto-normalize + enrich IPs/domains/hashes

- auto-isolate on firm detections

- case notes auto-created

BUT: automation is only as good as the playbook design + the last logic review. An automation that "auto-suppresses" the actual ransomware is worse than none.

Confirmed Incident Discipline (the psychological part)

- One **single incident commander** – no committee

- Deliberate pace, urgent communication** – feel the urgency but act in order

- Security folk speak in "I believe / I can prove / I suspect" – never overclaim to panicky stakeholders

- Write as you go; memory rots in a firefight

The meta-skill of IR is decision-making under uncertainty with partial information. Playbooks raise the floor; judgment raises the ceiling.

[← The Incident Response Lifecy...](#)

[Containment Strategies & Recov...](#)